Lab Webstrike

Penulis: Firman Maulana

Sebuah file mencurigakan terdeteksi di server web perusahaan, menimbulkan alarm di dalam intranet. Tim Pengembangan menandai anomali tersebut, mencurigai adanya aktivitas berbahaya. Untuk menangani masalah ini, tim jaringan menangkap lalu lintas jaringan yang kritis dan menyiapkan file PCAP untuk ditinjau. Tugas Anda adalah menganalisis file PCAP yang disediakan untuk mengetahui bagaimana file tersebut muncul dan menentukan sejauh mana adanya aktivitas yang tidak sah. Untuk link lab tersebut klik disini yaa!

soal 1, Identifying the geographical origin of the attack facilitates the implementation of geo-blocking measures and the analysis of threat intelligence. From which city did the attack originate?

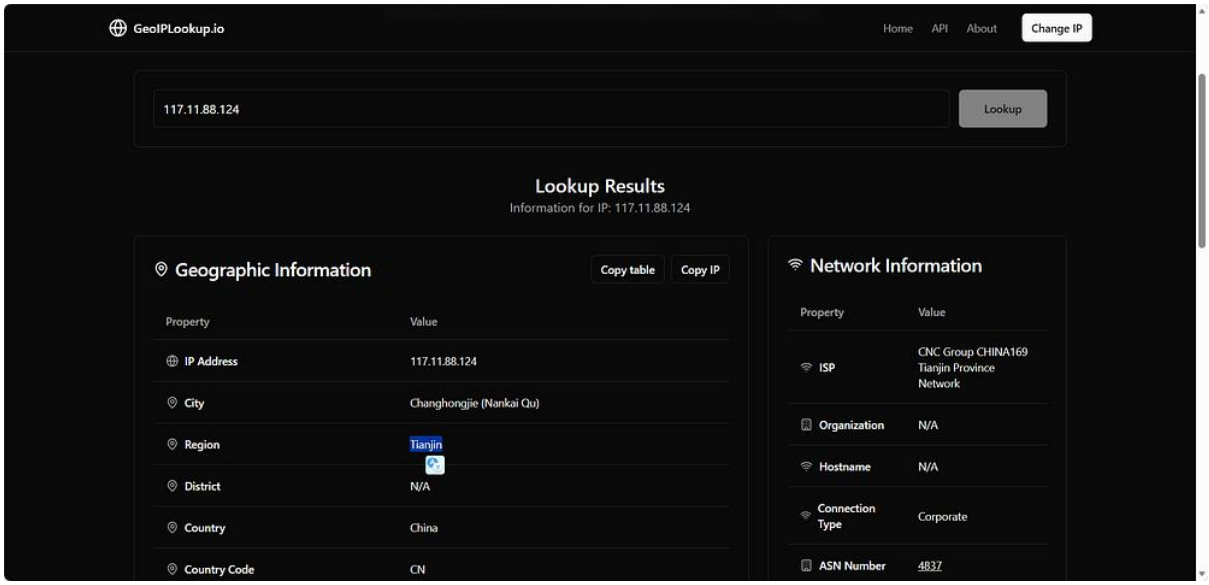
Langkah awal untuk mencari kota yang melakukan serangan yaitu dengan cara mencari IP penyerang terlebih dahulu. Langkah awal yaitu dengan membuka menu statistik pada Wireshark, memilih menu Protocol Hierarchy. Di sini saya bertujuan untuk mengecek peta masalah pada pcap ini untuk mempermudah analisis sumber masalah.

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDUs
Frame	100.0	355	100.0	48166	1313	0	0	0	355
Ethernet	100.0	355	10.3	4970	135	0	0	0	355
Internet Protocol Version 4	100.0	355	14.7	7100	193	0	0	0	355
Transmission Control Protocol	100.0	355	74.9	36096	984	310	12489	340	355
Hypertext Transfer Protocol	12.7	45	46.0	22167	604	23	8982	244	45
MIME Multipart Media Encapsulation	0.6	2	2.9	1375	37	2	1375	37	2
Line-based text data	3.7	13	15.5	7454	203	13	7454	203	13
HTML Form URL Encoded	0.3	1	0.0	11	0	1	11	0	1
Compuserve GIF	1.7	6	2.8	1346	36	6	1346	36	6

Pada hasil dari menu tersebut, terdapat lonjakan yang janggal pada *Line-based text data*. Bagian tersebut merupakan pintu masuk untuk data yang tidak terenkripsi, yang dapat dibaca oleh manusia sebagai teks. Adanya hal seperti ini menjadi suatu pertanda bahwa ada hal yang harus dicek lebih lanjut, karena seharusnya protokol tersebut lebih rendah atau bahkan tidak ada trafiknya sama sekali. Untuk itu, saya memfilter log pada pcap tersebut dengan menuliskan *http.request.method,* dengan filter tersebut akan menghasilkan log saat ada POST dan GET pada jaringan.

No.	Time	Source	Destination	Protocol	Length	Info
73	57.538074	117.11.88.124	24.49.63.79	HTTP	416	GET /admin/uploads HTTP/1.1
83	63.058836	117.11.88.124	24.49.63.79	HTTP	410	GET /uploads HTTP/1.1
93	69.755241	117.11.88.124	24.49.63.79	HTTP	409	GET /admin/ HTTP/1.1
103	75.201187	117.11.88.124	24.49.63.79	HTTP	418	GET /reviews/uploads HTTP/1.1
107	75.207010	117.11.88.124	24.49.63.79	HTTP	419	GET /reviews/uploads/ HTTP/1.1
109	75.228143	117.11.88.124	24.49.63.79	HTTP	376	GET /icons/blank.gif HTTP/1.1
114	75.228890	117.11.88.124	24.49.63.79	HTTP	375	GET /icons/back.gif HTTP/1.1
121	75.229218	117.11.88.124	24.49.63.79	HTTP	377	GET /icons/image2.gif HTTP/1.1
138	84.150547	117.11.88.124	24.49.63.79	HTTP	480	GET /reviews/uploads/image.jpg.php HTTP/1.1
267	191.372660	24.49.63.79	117.11.88.124	HTTP	228	POST / HTTP/1.1 (application/x-www-form-urlencoded)
326	288.389226	117.11.88.124	24.49.63.79	HTTP	470	GET /reviews/uploads/ HTTP/1.1
330	288.400569	117.11.88.124	24.49.63.79	HTTP	427	GET /icons/blank.gif HTTP/1.1
335	288.401559	117.11.88.124	24.49.63.79	HTTP	426	GET /icons/back.gif HTTP/1.1
340	288.401886	117.11.88.124	24.49.63.79	HTTP	428	GET /icons/image2.gif HTTP/1.1

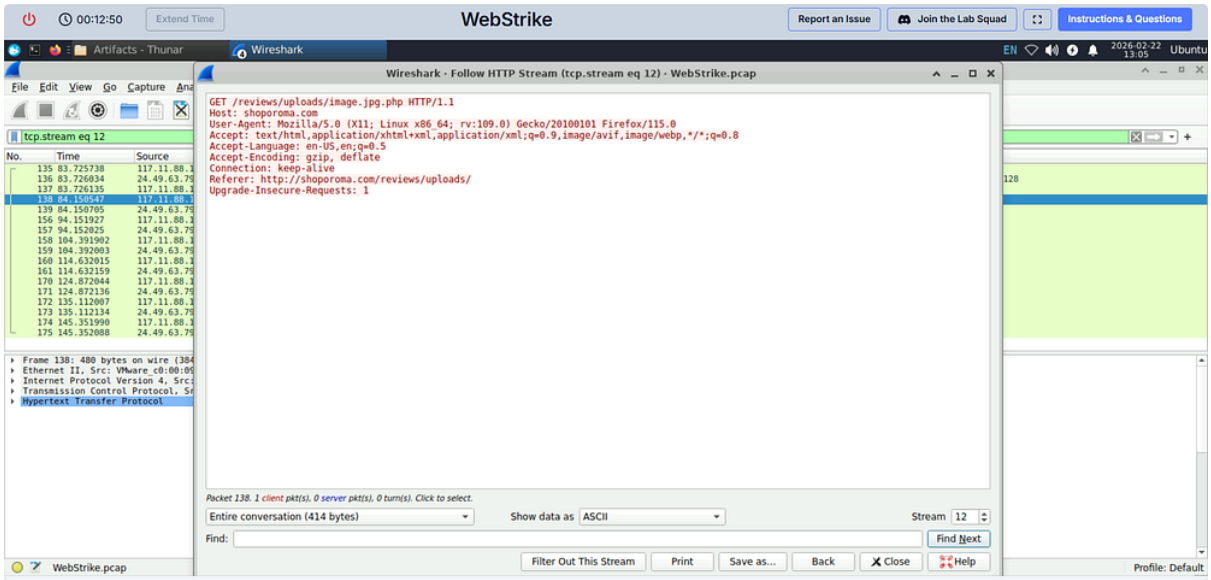
Pada analisa file pcap tersebut, terdapat IP yang mencurigakan,karena mengupload file image.jpg.php. hal ini janggal, dikarenakan file tersebut dinamakan image dan ada .jpgnya tetapi format akhirnya .php. setelah itu saya cari lokasi soucre IP tersebut menggunakan geoiplookup.io



Dalam analisis menggunakan tool tersebut, ip terletak di area Tianjin dan itu menjadi jawaban soal nomor 1 pada challenge ini.

Soal ke-2, Knowing the attacker's User-Agent assists in creating robust filtering rules. What's the attacker's Full User-Agent?

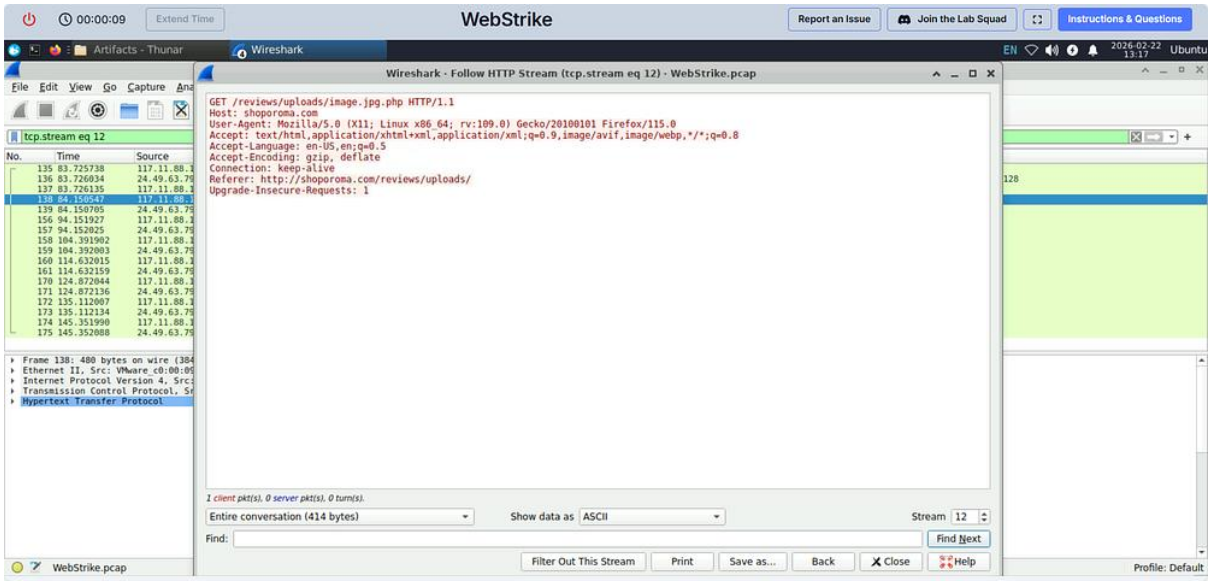
Pada nomor 2 ini, yaitu mencari user-agent pada file mencurigakan tersebut, dengan cara mengikuti HTTP Stream pada log mencurigakan tersebut.



Berdasarkan temuan saya, user agent tersebut adalah "*Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0*". Temuan tersebut menjadi jawaban pada nomor 2.

Soal 3: We need to determine if any vulnerabilities were exploited. What is the name of the malicious web shell that was successfully uploaded?

Pada nomor 3 ini, yaitu mencari nama webshell yang sukses ditanamkan pada website, di mananama webshell tersebut berada di bagian yang sama pada Follow HTTP Stream, yaitu *image.jpg.png*.

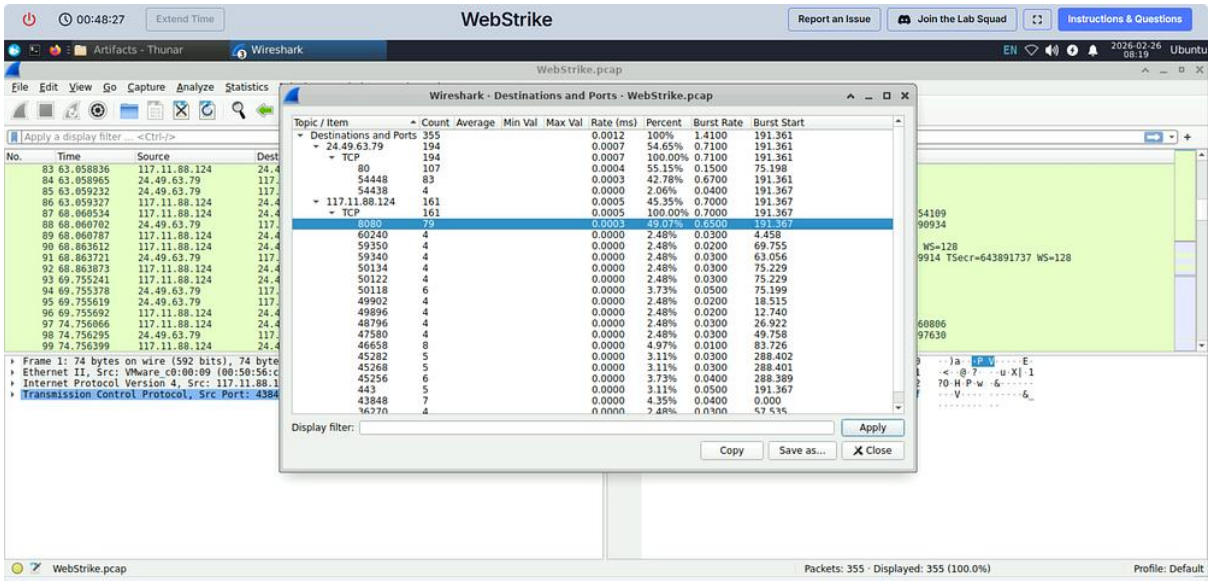


soal 4, Identifying the directory where uploaded files are stored is crucial for locating the vulnerable page and removing any malicious files. Which directory is used by the website to store the uploaded files?

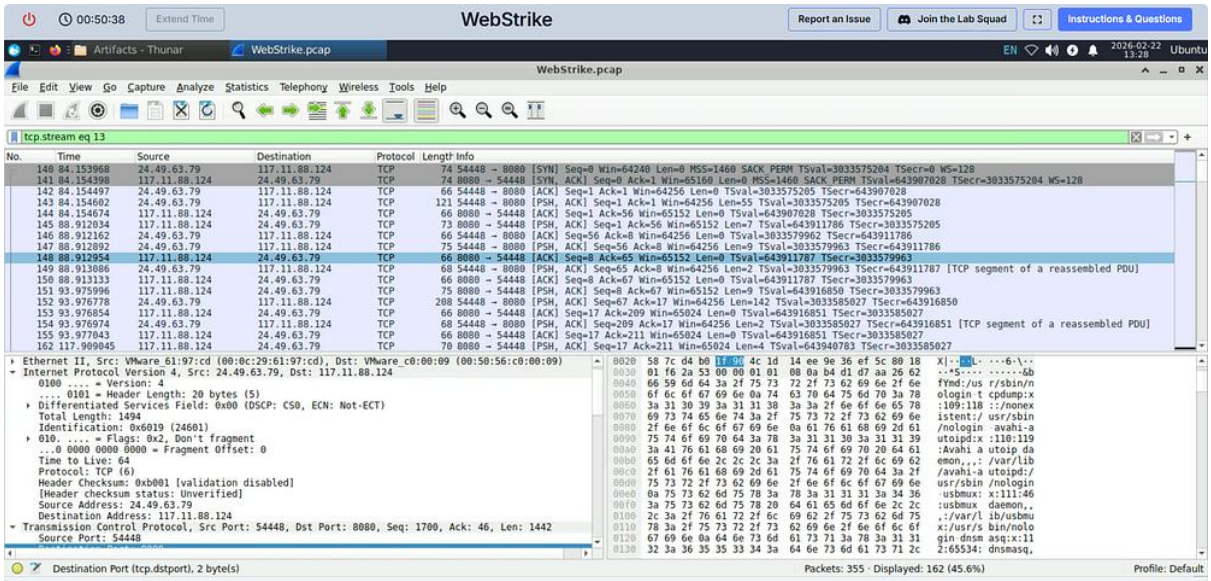
Pada nomor ke-4 ini, yaitu mencari direktori yang digunakan untuk mengunggah file pada website tersebut, yaitu */reviews/uploads/*, informasi ini juga terdapat pada menu yang sama dengan sebelumnya.

soal 5, Which port, opened on the attacker's machine, was targeted by the malicious web shell for establishing unauthorized outbound communication?

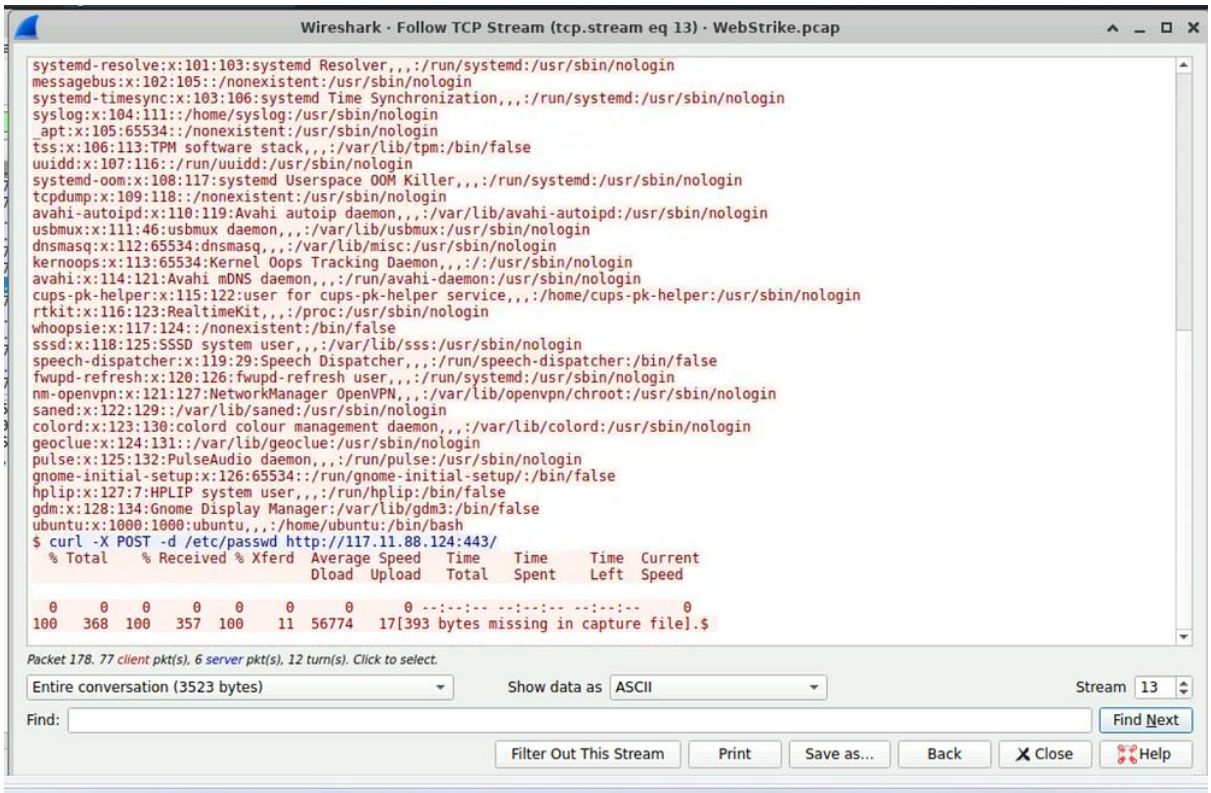
Pada soal ke 5, ini menjadi titik krusial dimana yang harus di cari itu adalah port mana yang digunakan untuk melakukan serangan oleh penyerang, dikarenakan tidak mungkin port 443 menjadi titik masuk penyerang, dikarenakan tidak akan mudah untuk menyisipkan file berbahaya pada port tersebut, karena terenkripsi.



Dari analisa ini, ternyata ada port 80 dan 8080 yang terbuka dan digunakan, di mana itu merupakan port yang tidak terenkripsi. Penyerang kemungkinan masuk melalui port 8080 atau port 80.



Setelah dilakukannya filter, saya melakukan follow TCP Stream terhadap salah satu log pada port 8080, dan ternyata benar pada port tersebut, penyerang sudah berhasil masuk ke server dan mengirim pasword ke IP penyerang dengan port 443.



soal 6, Recognizing the significance of compromised data helps prioritize incident response actions. Which file was the attacker attempting to exfiltrate?

Pada soal ke 6 ini, yaitu harus menganalisa apa yang diektrak oleh penyerang, di dalam Stream tersebut, sudah jelas jika penyerang mengirimkan sebuah direktori atau file berupa *passwd* kepada IP miliknya melalui port 443.

Kesimpulan

Pada challenge tersebut, jika saya analisis, kesimpulannya, penyerang masuk ke dalam server melalui pengunggahan skrip PHP berbahaya, di mana file php tersebut dimanipulasi agar dapat berbaur dengan file gambar dan lolos dari pengawasan. Setelah penyerang berhasil mengunggah skrip tersebut, penyerang dapat mengontrol server sehingga kemungkinan skrip yang dikirim merupakan C2 atau malware yang dapat melakukan Command and Control dari jarak jauh setelah skripnya ditanamkan di server.

Setelah dapat dikontrol oleh penyerang, dia mencari password yang disimpan di direktori mana, dan setelah ditemukan, dia mengirimnya langsung ke IP-nya dengan port 443.

Dari challenge ini, kita dapat memahami bahwa mengirim skrip berbahaya ke dalam web server sangat berbahaya jika terjadi, karena dapat mengeksploitasi server, entah mengirim kredensial atau hal-hal lain yang berharga bagi pemilik web server.